

Som Chandra

somchandra.infosec@gmail.com | +91 9507988170 | github.com/somchandra17
linkedin.com/in/somchandra17 | tryhackme.com/p/somchandra17 | somm.tf

TECHNICAL SKILLS

Application and API Security: Gray-box web and API penetration testing (VAPT), OWASP Top 10, GraphQL security, CVSS scoring and SLA mapping

Mobile Offensive Security: Android and iOS SAST/DAST, OWASP MASTG/MASVS, Frida, objection, SSL pinning, root and jailbreak detection

Security Automation: Burp extension development (Montoya API, Extender API), Python, Kotlin, Java, FastAPI, VAPT to Jira

Attack Surface: External recon and exposure checks (subfinder, amass, httpx, testssl.sh), Nessus scanning, and CVE validation before public templates

Incident Response: Root-cause analysis, attack reconstruction, credential-exposure response, read-only rotation checks

Tools: Burp Suite, Frida, objection, adb, drozer, apktool, Nessus, nuclei, libimobiledevice, Docker, Jira, AWS

PROFESSIONAL EXPERIENCE

Cyber Security Engineer, MoveInSync – Bengaluru, India June 2025 – Present

- Reported 156 FY2025-26 VAPT findings across 10 internal cycles on employee-transport web, API, and Android products, including an unauthenticated API, IDOR in billing reports, and a WebSocket leaking live cab location
- Drove CVSS-to-SLA remediation with engineering across 180 reported tickets, with 100+ assigned and about 93% of assigned tickets closed
- Led root-cause analysis and attack reconstruction for a CI/CD server intrusion, tracing 3 separate attacker visits from on-host artifacts, and wrote the hardening worklist for the rebuilt host
- Drove credential-exposure response, triaging the leaked secrets into a per-service rotation tracker, checking keys read-only from the owner side, and catching keys reported as rotated that were still live
- Built a 9-phase Android DAST framework with adb, drozer, and apktool that cut per-app assessment from 1–2 days to under 1 hour, and that work contributed to the team declining a paid PortSwigger Burp DAST purchase
- Built GQLSweep, a Burp extension running 170+ automated GraphQL checks across 12 categories, surfacing alias-abuse denial of service and excessive data exposure later confirmed by an external vendor
- Owned external VAPT across 4 vendors and 4 major cycles on web, Android, iOS, and a driver app, including false-positive filtering (such as an SSL-pinning bypass that needed a rooted device and did not reproduce on production), compensating controls the vendor accepted, and revalidation
- Built a Java Burp extension that decodes and re-encodes a zlib-compressed integer-array protocol, unlocking active testing of that traffic, and later ported the extension to the Montoya API
- Ran the first in-house AI and LLM assessment of an internal chatbot, where prompt injection bypassed tool-persona and policy controls, and turned that work into a reusable method
- Migrated Nessus from Azure Windows to hardened AWS Linux and automated weekly Advanced scans
- Built External VAPT to Jira, which files an external VAPT report into Jira in one click instead of a 4–5 hour manual pass, and does not post until it is approved
- Built VAPT Revalidator, a FastAPI worker that retests IDOR and broken access control through Burp and writes the Jira comment only after a person approves it
- Manually validated Apache Tomcat CVE-2025-66614 and CVE-2026-24734 on UAT before public nuclei templates existed, and shared the results as a team reference

Technologies: Burp Suite, Frida, Python, Java, Nessus, FastAPI, AWS

Application Security Intern, MoveInSync – Bengaluru, India Mar 2024 – June 2025

- Raised critical reflected XSS findings on the transport-management API in manual and automated VAPT, and published the report
- Escalated critical issues to engineering leads the same day during a production-clone assessment
- Surfaced a gap on an employee-data API call during an authentication retrofit, and engineering wrapped the call in authentication

- Cyber Security R&D Intern**, Securaeon Initiative – Remote Feb 2022 – July 2022
- Created security walkthroughs, proof-of-concept material, and practical lab content for upcoming cybersecurity products and courses
- Security Researcher**, Bugcrowd – Remote Oct 2021 – Dec 2021
- Reported web vulnerabilities through open bug bounty programs, and wrote impact, proof of concept, and remediation context for program security teams

PROJECTS

TrashDroid Mar 2026 – July 2026

github.com/Somchandra17/TrashDroid

- Published the Android DAST method as a 9-phase Python framework orchestrating adb, drozer, apktool, and sqlite3
- Covered exported-component SQL injection and path traversal, SQLite deep-dumps, logcat, heap and proc maps, ADB backup, manifest review, and secret detection
- Added Frida 17 bypasses for SSL pinning, root detection, and debugger detection, plus an AI-review triage package

TrashiOS June 2026

github.com/Somchandra17/TrashiOS

- Published the iOS counterpart as a 13-phase SAST and DAST flow on a USB-connected jailbroken device
- Mapped checks to OWASP MASTG and MASVS and triaged an internal UAT iOS build into an AI-ready report

Burp AI Agent Apr 2026

github.com/six2dez/burp-ai-agent

- Merged an NVIDIA NIM backend and a reworked OpenAI-compatible backend, including HTTP 429 handling, into six2dez/burp-ai-agent (PR 44)

TrashRecon Mar 2026 – June 2026

github.com/Somchandra17/TrashRecon

- Dockerized external recon across 17 tools and 10 phases, with resume support and structured JSON so finished tool outputs are skipped on rerun

TrashFrame June 2026

github.com/Somchandra17/TrashFrame trash-frame.vercel.app

- Built a Next.js app that turns a Spotify album or song link into a printable poster, with 14 themes and DPI export for real frames

w-bonkers July 2026

github.com/Somchandra17/w-bonkers

- Built an NSE portfolio copilot for Claude Code and Codex, with a deterministic plan file, Todoist order tasks, and local archives, and no auto-trading

CERTIFICATIONS

eWPTXv2, eLearnSecurity Web Application Penetration Tester eXtreme Jan 2023

CompTIA Security+ (SY0-701) Dec 2024

ACHIEVEMENTS

- Earned Hall of Fame recognition from Mastercard for SSTI escalated to LFI (P1), Rakuten for session fixation (P2), and Chaturbate for stored XSS (P2)
- Received 20+ NCIPC India responsible-disclosure acknowledgments for client-side authentication bypass, missing rate limits, XSS, SQL injection, and account takeover
- Ranked in the top 1% on TryHackMe
- Placed 5th at OWASPLPU CTF 2022, 9th at WTFCTF 2022, and 34th at RuCTF 2022

EDUCATION

B.Tech, Computer Science and Engineering (Hons.), Lovely Professional University – Jalandhar, India May 2025

- Specialized in cybersecurity and blockchain